

# Conducting a Risk Assessment of an Access Control System (3e)

Access Control and Identity Management, Third Edition - Lab 02

---

Student:

Christopher Phan

Email:

cphan@udallas.edu

Time on Task:

Progress:

50%

Report Generated: Saturday, June 4, 2022 at 3:55 PM

## Guided Exercises

### Part 1: Research Risk Assessment Standards

4. **Compare** the requirements for access control systems in the PCI DSS to those in the HIPAA Security Rule. **Describe** the level of detail found in each standard and how each standard might be easier and more challenging to meet compared with the other.

There are multiple requirements for the access control systems for PCI DSS. All data is to be documented, kept up to date, in use, and known to all affected parties. That data must be assigned properly and understood, only given to those with the necessary access, based on the principle of "least privilege". For this access must be appropriately assigned to personnel, interviews must be conducted and personnel must be authorized and approved, reviewal of the privileges and assignments for that personnel as all of it must be clearly defined for all data involved. Lastly, that all access to these systems must be managed by controlled system to manage the access and traffic, everything must be on a need to know basis, permissions dealt out to those necessary and enforced, and "deny all" by default. For HIPPA, there is also multiple requirements for their access control system with a similar direction. The requirements consist of unique user identification for all personnel and emergency access procedure (both being required for all concerned with HIPPA), automatic logoff in all electronic sessions, encryption and decryption mechanisms in place, audits for all procedures both electronic and digital, policies requiring integrity to protect all PHI, a mechanism that authenticates all electronic PHI, a authentication process for any entities seeking PHI, and security measures that guard transmission from any third party interference. Both are highly detailed, though each in a different focus in their placement, one specializing in healthcare, another in transaction. The one that would be the most challenging to meet would be standards set by HIPPA, due to it being in a much broader scope as well as placement of physical barriers for accessing information. PCI DSS seems to be more of internal review, while HIPPA has a standards set for even persons that are outside of the healthcare system, enforced to keep in track of who can access it outside of the organization.

### Part 2: Conduct a Risk Assessment

## Conducting a Risk Assessment of an Access Control System (3e)

Access Control and Identity Management, Third Edition - Lab 02

---

1. Conduct a risk analysis of this environment using the version of PCI DSS that you downloaded in Part 1 of this lab. **Document** at least five control gaps that exist in the environment. You may make assumptions about information not provided in this scenario, if necessary.

First control gap is that any cashier can access the POS system at any store, only assigned to the one that they were hired for. Second control gap is that managers are not taken out from the system immediate upon dismissal, leaving someone capable of accessing the system if they are not necessary to the need to know. Third control gap is that managers do not need access to the back-end server, the rule of "least privilege" needs to be enforced, their job requirements do not necessitate access to something that high end in priority. Fourth control gap is that all cashiers have easily guessed usernames, creating a possibility of any persons to access their accounts if the passwords can be figured out. Fifth control gap is that the IT staff review security policies annually, when they should be reviewing every 6 months instead. Sixth control gap is that users can retry their password nearly 10 times, there should be a rule to establish that immediately "deny all" upon first failure.

2. Identify controls that will mitigate each of the five deficiencies you identified in the previous step. **Create** a prioritized list of these actions.

Controls that would be in place to mitigate the deficiencies mentioned before are: 1. Limiting the access for cashiers in Ricky's Fried Chicken to the store that they were assigned to. 2. Take away all access from managers immediately upon their leave or removal, to limit those who are in the "need to know." 3. Take away access to the back-end servers from managers, as they do not need to have access to those systems in their job assignment. 4. Cashiers need to make personal accounts, where they create their own username to limit further any outside or third party access from possible guessing. 5. Enforce that IT staff meet every 6 months for review of security policies. 6. Limit the amount of retries for staff on logging in, to create a more secure workplace.

### Challenge Exercise

1. What risk assessment standard would be the best approach for evaluating this system? Depending on the system, you may use one of the standards already discussed in this lab or identify an alternative standard more appropriate for your environment. **Provide** a brief description of the system, **identify** the standard that you used and **describe** why it is appropriate for the system.

Incomplete

2. Conduct a risk assessment of the system against those standards to the best of your ability. If you are not familiar with the detailed workings of the systems, you may make assumptions to facilitate your risk assessment. **Create a list** of the gaps that exist between the system and the standard you used.

Incomplete

3. **Develop a prioritized list** of risk mitigation activities which, if followed, would address the issues raised in your gap analysis from step 2.

Incomplete